Risk in Practice

Plenary

Enterprise Cyber Security

Check-in

- Sit together in your assessment group.

The example

Larchfield Print, a fictional case

- An online print shop with about 40 staff. Customers order and pay on its web shop.
- Assets: **customer accounts**, **card-payment records**, **order files** and the **web shop** itself.
- Staff reach the file server from home with a **password-only** login.
- Backups run each night to a storage box in the office.

Evidence for one month

Counts from the fictional logs

Observation	Count	Note
Failed customer logins from many addresses	4,200 in a week	900 addresses, one attempt each
Customer accounts with a later successful login	31	Logins after failures from many addresses
Failed staff remote logins	6	Password-only; one success from an unknown country
Nightly backups that failed without an alert	2 of 30	No check that backups restore
Order-file export to a new address	1	12,000 order records
Web shop outage after a plug-in update	3 hours	No staged testing

These are the log counts. Add external sources where they help, and say what the logs cannot show.

Activity 1: build your scales

- Choose **two** assets from Larchfield's list.
- Write a **five-level likelihood scale**, in how often the incident happens. Use the evidence table to judge.
- Write a **five-level consequence scale** for each asset, in a unit you can count. The specification calls this **impact**.
- Write the scales on paper. Name the unit in every level.
- Justify each scale with a source: your **logs**, an **external source**, or both.

Strengthen your scales

Relevant external sources

- **Strengthen** each scale with relevant external sources. Use published frameworks, regulatory guidance, or data on what comparable incidents have cost, to justify each level.
- Kinds of evidence: **logs**, **academic literature**, **peer-reviewed research**, **state guidance**, **regulators** and **news reporting of real incidents**.
- For every rating, say whether it rests on your **logs**, on an **external source**, or on **both**.

Named sources to start from

Sources you can transfer to your own system

Source	Use it for
Thomas et al. (2017), peer-reviewed	Account takeover after stolen passwords are reused
PCI DSS v4.0.1 (2024), requirement 8.4.3	Remote access to systems that hold card data
ICO (2020), British Airways penalty notice	What a card-data breach has cost in fines (£20m)
NCSC (2018), password policy	Multi-factor authentication for remote access
Burnap (2026), CyBOK, sections 5.4 and 6.3	Risk statements, and the ISO/IEC 27005 process
Cox (2008), peer-reviewed	Limits of risk matrices

Find sources of your own as well. Cite each one, and say which rating it supports.

Test your scale

Before you move on

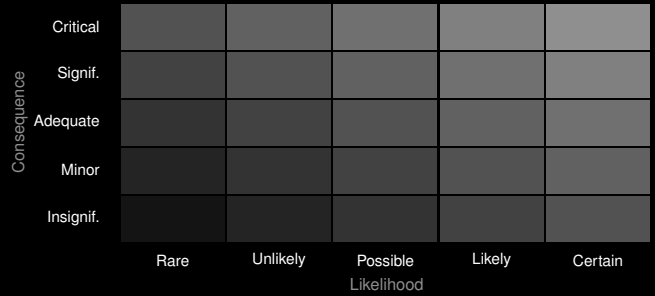
- Every level has a **unit**.
- The levels do not **overlap**, so one event fits one level.
- The top level is the **worst credible** case, not the worst imaginable one.
- A group reading your scale would place the same event at the same level.
- Each rating says whether it rests on your **logs**, an **external source**, or both.

Activity 2: place three risks

- Choose **three** risks from the evidence table: at least one **malicious**, and one **non-malicious**.
- For each risk, give its likelihood and consequence on your scales, and the **row of evidence** that supports it.
- For every rating, say whether it rests on your **logs**, on an **external source**, or on **both**.
- Write down what the evidence **cannot** tell you.
- Every member speaks at least once.

Your matrix

Place each risk, using your scale labels



Draw it on paper, with the labels from your own scales.

Activity 3: treat the top risk

- Take the **highest** of your three risks.
- Choose **avoid**, **reduce**, **transfer** or **accept**, and say why.
- State the **new level** after treatment, and the reasoning.
- Name one **metric** you can count from the logs, and one **first step** for week 1.

Transfer

Same steps, your own system

- Scope, assets and the attack surface first.
- Scales with units and sources, built from those assets.
- Evidence rows, each with its count and its limit.
- Place, evaluate, treat, then monitor.

Reflect

- One sentence each: your scales, your top risk and your treatment.
- The thing your group is **least sure** of, and the evidence that would settle it.

Before you leave

Admin

- Update the **workload record** with what your group did today.
- Agree your next meeting, and when each member will be contacted.
- If a member cannot be reached, tell the **course coordinator** as soon as possible.

Risk in Practice

Plenary

Enterprise Cyber Security